

MetricFlow Vendor Risk Assessment

Tier 1 SaaS vendor assessment | Status date: September 10, 2026

SIMULATED DOCUMENT FOR PUBLIC PORTFOLIO USE

Vendor ID	V-002
Service	Cloud analytics and API integration
Business owner	Data Engineering
Data and access	Customer PII, confidential analytics, production API, and service account
Inherent risk	Critical, 19/19
Residual risk	4 High and 4 Medium risks
Decision	Approve with Conditions
Next review	January 15, 2027

Decision

MetricFlow can proceed with conditions. The vendor supports critical reporting workflows and requires production connectivity. Four High residual risks must be resolved or formally accepted before unrestricted onboarding.

Production data must not be shared until the contract defines a security incident notification window. Security must also approve the approach for legacy break-glass accounts and High or Critical vulnerability exceptions. If launch occurs before the DR retest, the business owner must document temporary acceptance of the recovery risk.

Assessment scope

Activity	Result
Inherent risk assessment	Six factors scored 19/19, resulting in Critical risk and Tier 1 due diligence.
Security questionnaire	30 control questions across IAM, data security, logging, vulnerability management, SDLC, incident response, BCP/DR, privacy, fourth-party risk, and supporting domains.
Evidence review	10 evidence categories requested. Nine received. Cyber insurance remains open.
SOC 2 review	Type II, unqualified opinion, Security and Availability in scope, one relevant exception, and cloud hosting carved out.
Risk treatment	Eight MetricFlow risks documented with owners, target dates, evidence requirements, and escalation paths.

Residual risk summary

ID	Finding	Residual	Required action
R-001	MFA is not enforced on two legacy break-glass accounts.	High 13	Enforce MFA or approve a temporary compensating control.
R-004	Engineering can approve release of High findings without Security approval.	High 14	Add Security approval to the exception process.
R-005	The contract does not define a security incident notification window.	High 11	Execute the security addendum before production data is shared.
R-006	The latest recovery exercise completed in 5.5 hours against a 4-hour RTO.	High 14	Complete corrective actions and provide a passing retest.
R-002	Two service-account secrets rotate annually rather than quarterly.	Medium 7	Move the affected secrets to quarterly rotation.
R-003	Backups may retain customer data for 180 days after termination.	Medium 8	Align deletion terms and procedures with the approved requirement.
R-007	Critical subprocessors are assessed at onboarding but not periodically.	Medium 7	Add periodic reassessment for critical subprocessors.
R-008	Two Medium penetration-test findings remain open past the vendor target date.	Medium 5	Obtain closure and retest evidence.

Approval conditions

Condition	Owner	Target
Execute incident notification language.	Legal / Procurement	Sep 30, 2026
Enforce MFA for legacy break-glass accounts or approve a temporary exception.	Vendor Security / Security	Oct 15, 2026
Require Security approval for High or Critical vulnerability exceptions.	Vendor AppSec / AppSec	Oct 20, 2026
Complete DR corrective actions and a retest within the 4-hour RTO.	Vendor BCP Lead / Business Owner	Oct 30, 2026

Evidence considered

Evidence	Review result
SOC 2 Type II	Unqualified opinion. Bridge letter, CUEC ownership, and carved-out cloud assurance remain follow-up items.
ISO 27001 certificate	Current and scoped to the production SaaS environment. Latest Statement of Applicability requested.
Penetration test	No Critical or High findings. Two Medium findings are overdue.
BCP/DR	RTO 4 hours and RPO 1 hour. Latest regional recovery exercise completed in 5.5 hours.
Incident response	Plan is current and an annual tabletop was completed. Contract notification timing remains open.
Retention and deletion	Backups may be retained for 180 days after termination.
Cyber insurance	Certificate not received.

Monitoring

- Review High-risk actions monthly until they are closed or formally accepted.
- Perform the Tier 1 reassessment by January 15, 2027.
- Open an out-of-cycle review for a material security-rating decline, confirmed incident, significant service change, new critical subprocessor, assurance expiry, or repeated outage.

Final recommendation

Approve with Conditions. The vendor provided evidence of encryption, logging, access reviews, change controls, incident response testing, and independent assurance. Approval remains conditional on the contractual notification clause, privileged-access remediation, exception-governance change, and DR retest.